Report di Vulnerability Assessment – Metasploitable

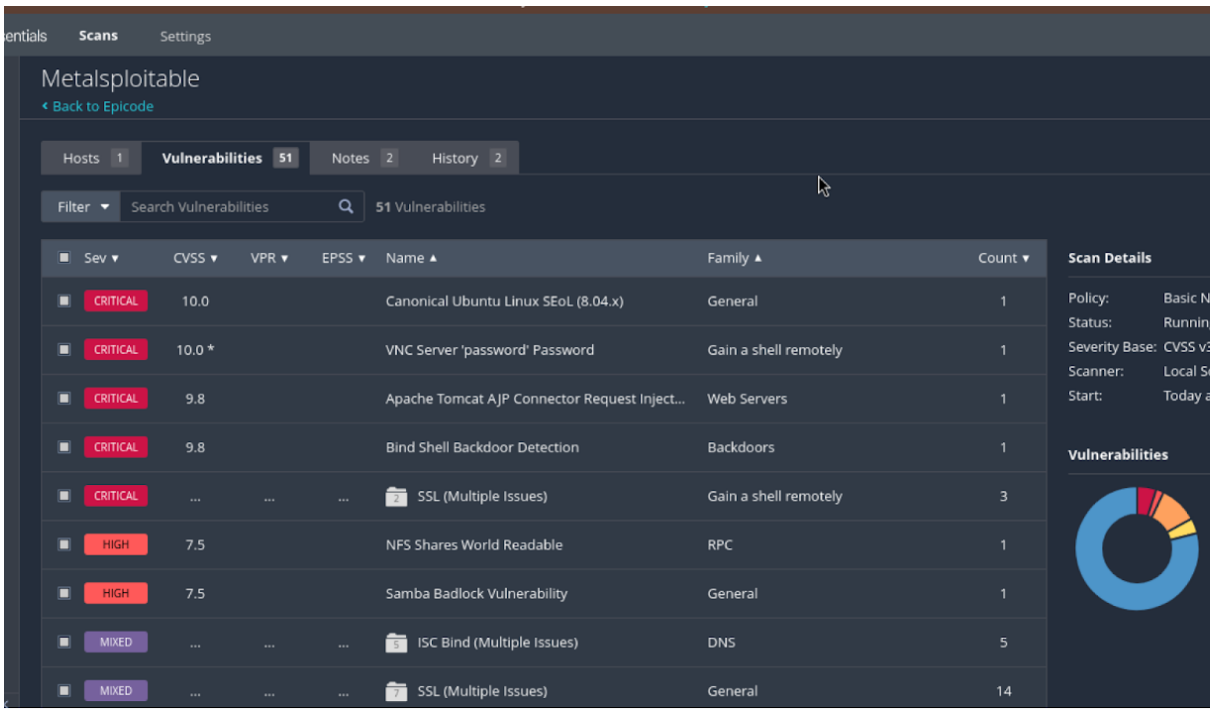
Corso: Cybersecurity Analyst
Modulo: W12D1 (Pratica)
Studente:Emanuele cestari
Data: 16/03/2026

Introduzione
Questo report descrive l'attività di Vulnerability Assessment eseguita sulla macchina vulnerabile Metasploitable utilizzando lo scanner di vulnerabilità Nessus dalla
macchina Kali Linux.

DESCRIZIONE DELLA TRACCIA:

Effettuare un Vulnerability Assessment con Nessus sulla macchina Metasploitable indicando come target solo le porte comuni (potete scegliere come scansione il «basic network scan», o l'advanced e poi configurarlo) A valle del completamento della scansione, analizzate attentamente il report per ognuna delle vulnerabilità riportate, approfondendo qualora necessario con i link all'interno dei report e/o con contenuto da Web. Gli obiettivi dell'esercizio sono: Fare pratica con lo strumento, con la configurazione e l'avvio delle scansioni Familiarizzare con alcune delle vulnerabilità note che troverete spesso sul vostro percorso da penetration tester

Tipo di Scansione Basic Network Scan: vulnerabilità in Nessus



Didascalia

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

There's an error with your feed. Click here to view your license information.

tenable Nessus Essentials Scans Settings kali

FOLDERS
My Scans
Epicode
All Scans
Trash

RESOURCES
Policies
Plugin Rules

Metalsploitable Vulnerability Scan / Plugin #134862

Back to Vulnerabilities

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 63 Remediations 2 Notes 3 History 1

CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also

http://www.nessus.org/u?8ebe6246
http://www.nessus.org/u?4e287adb
http://www.nessus.org/u?cbc3d54e
https://access.redhat.com/security/cve/CVE-2020-1745
https://access.redhat.com/solutions/4851251
http://www.nessus.org/u?dd218234
http://www.nessus.org/u?dd772531
http://www.nessus.org/u?2a01d6bf
http://www.nessus.org/u?3b5af27e
http://www.nessus.org/u?9dab109f

Plugin Details

Severity:	Critical
ID:	134862
Version:	1.62
Type:	remote
Family:	Web Servers
Published:	March 24, 2020
Modified:	January 19, 2026

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: High
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSV3 Impact Score: 5.9
Threat Sources: No recorded events

Vulnerabilità 1 APACHE TOMCAT AJP:Questa vulnerabilità consente a un attaccante remoto non autenticato di
sfruttare il protocollo AJP per accedere a file sensibili presenti sul server.

Dettagli ufficiali della vulnerabilità CVE-2020-1745 nel National Vulnerability Database (NVD)

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST NATIONAL VULNERABILITY DATABASE NVD

VULNERABILITIES

CVE-2020-1745 Detail

MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

A file inclusion vulnerability was found in the AJP connector enabled with a default AJP configuration port of 8009 in Undertow version 2.0.29.Final and before and was fixed in 2.0.30.Final. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and trigger this vulnerability to gain remote code execution.

QUICK INFO

CVE Dictionary Entry:
CVE-2020-1745
NVD Published Date:
04/28/2020
NVD Last Modified:
11/21/2024
Source:
Red Hat, Inc.

nvd.nist.gov/vuln/detail/CVE-2020-1745

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD **Base Score:** 9.8 CRITICAL **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CNA: Red Hat, Inc. **Base Score:** 8.6 HIGH **Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:L

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.gov.

URL	Source(s)	Tag(s)
https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2020-1745	CVE, Inc., Red Hat	Issue Tracking, Third Party Advisory
https://meterpreter.org/cve-2020-1938-apache-tomcat-ajp-connector-remote-code-execution-vulnerability-alert/	CVE, Inc., Red Hat	Not Applicable
https://security.netapp.com/advisory/ntap-20240216-0011/	CVE, Inc., Red Hat	

nvd.nist.gov/vuln/detail/CVE-2020-1745

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.gov.

URL	Source(s)	Tag(s)
https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2020-1745	CVE, Inc., Red Hat	Issue Tracking, Third Party Advisory
https://meterpreter.org/cve-2020-1938-apache-tomcat-ajp-connector-remote-code-execution-vulnerability-alert/	CVE, Inc., Red Hat	Not Applicable
https://security.netapp.com/advisory/ntap-20240216-0011/	CVE, Inc., Red Hat	
https://www.cnvd.org.cn/webinfo/show/5415	CVE, Inc., Red Hat	Not Applicable
https://www.tenable.com/blog/cve-2020-1938-ghostcat-apache-tomcat-ajp-file-readinclusion-vulnerability-cnvd-2020-10487	CVE, Inc., Red Hat	Not Applicable

Weakness Enumeration

CWE-ID	CWE Name	Source
NVD-CWE-noinfo	Insufficient Information	NIST
CWE-285	Improper Authorization	Red Hat, Inc.

Known Affected Software Configurations Switch to CPE 2.2

nvd.nist.gov/vuln/detail/CVE-2020-1745

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

https://meterpreter.org/cve-2020-1938-apache-tomcat-ajp-connector-remote-code-execution-vulnerability-alert/	CVE, Inc., Red Hat	Not Applicable
https://security.netapp.com/advisory/ntap-20240216-0011/	CVE, Inc., Red Hat	
https://www.cnvd.org.cn/webinfo/show/5415	CVE, Inc., Red Hat	Not Applicable
https://www.tenable.com/blog/cve-2020-1938-ghostcat-apache-tomcat-ajp-file-readinclusion-vulnerability-cnvd-2020-10487	CVE, Inc., Red Hat	Not Applicable

Weakness Enumeration

CWE-ID	CWE Name	Source
NVD-CWE-noinfo	Insufficient Information	NIST
CWE-285	Improper Authorization	Red Hat, Inc.

Known Affected Software Configurations Switch to CPE 2.2

Configuration 1 (hide)

cpe:2.3:a:redhat:undertow:*:*:*:*:*:*:*:* Show Matching CPE(s)	**Up to (including) 2.0.29**

Denotes Vulnerable Software

Are we missing a CPE here? Please let us know.

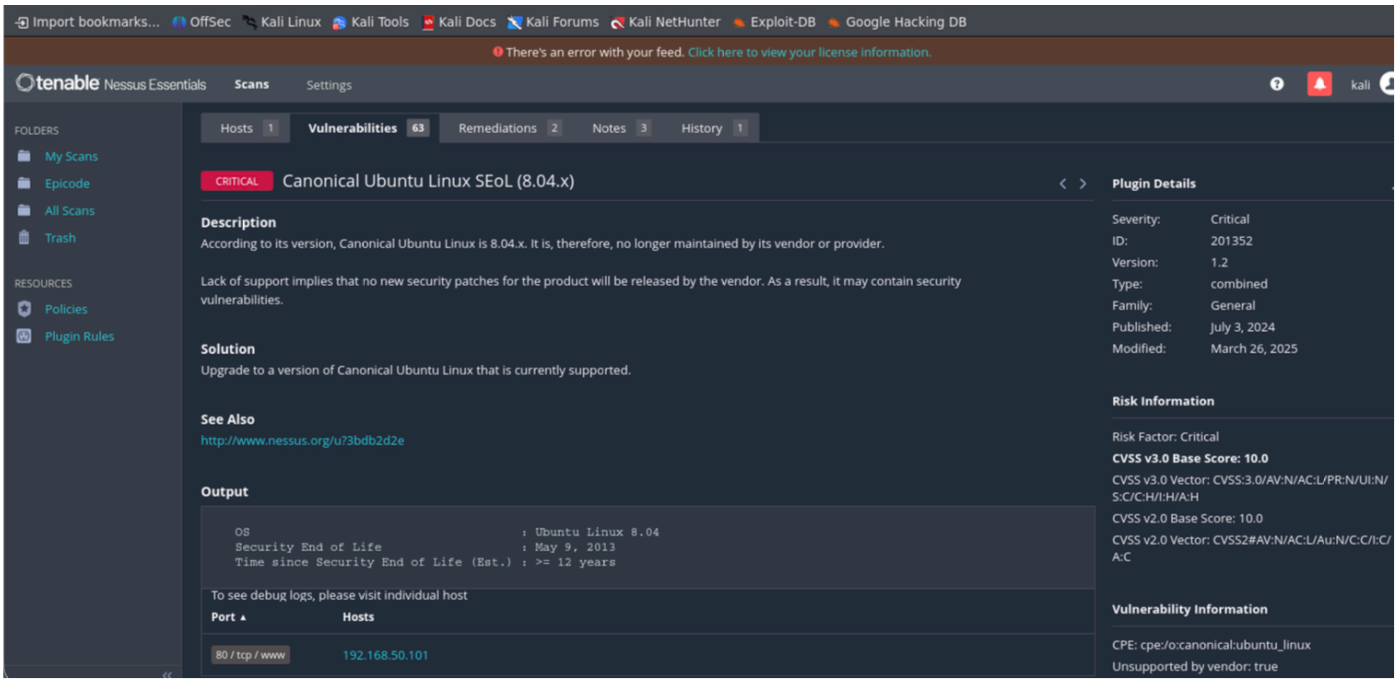
Change History

7 change records found show changes

La vulnerabilità è dovuta a una configurazione non sicura del connettore Apache JServ Protocol del server applicativo Apache Tomcat, che consente l'accesso diretto alla porta AJP da parte di utenti non autorizzati.
Un attaccante potrebbe sfruttare questa configurazione per leggere file sensibili del server, accedere ai file di configurazione, ottenere informazioni sull'applicazione o visualizzare il codice sorgente delle applicazioni web. In determinate condizioni, la vulnerabilità può anche essere sfruttata per caricare file malevoli ed eseguire codice remoto sul server.

Vulnerabilità Critica #2

Canonical Ubuntu Linux Security End-of-Life (Ubuntu 8.04)escrizione



Durante la scansione di sicurezza effettuata con Nessus, è stato rilevato che il sistema target utilizza Ubuntu versione 8.04, una versione del sistema operativo che ha raggiunto lo stato di Security End-of-Life (SEoL).

Questo stato indica che il sistema operativo non è più supportato dal produttore, Canonical Ltd., e non riceve più aggiornamenti di sicurezza né patch ufficiali. Di conseguenza, eventuali vulnerabilità presenti nel sistema non vengono più corrette dal vendor.

L'utilizzo di software obsoleto e non più mantenuto espone il sistema a numerose vulnerabilità note che possono essere facilmente sfruttate da un attaccante.

Impatto

La presenza di un sistema operativo End-of-Life rappresenta un rischio significativo per la sicurezza dell'infrastruttura.

Un attaccante potrebbe sfruttare vulnerabilità note presenti nel sistema per:

- ottenere accesso non autorizzato al sistema;
- eseguire codice malevolo;
- compromettere i servizi in esecuzione sul server;
- accedere a dati sensibili o riservati.

Poiché il sistema operativo non riceve più aggiornamenti di sicurezza, il rischio di compromissione aumenta progressivamente nel tempo.

Mitigazione

Per ridurre il rischio associato a questa vulnerabilità si raccomanda di:

- aggiornare il sistema operativo a una versione di Ubuntu attualmente supportata;
- applicare regolarmente gli aggiornamenti di sicurezza;
- implementare una politica di patch management per garantire il mantenimento costante degli aggiornamenti;
- limitare l'esposizione dei servizi di rete non necessari.

L'aggiornamento del sistema operativo a una versione supportata rappresenta la misura più efficace per mitigare questa vulnerabilità e garantire un adeguato livello di sicurezza del sistema.

Conclusione:

Il sistema analizzato presenta un livello di rischio elevato a causa della presenza di vulnerabilità critiche e software obsoleto. L'adozione di adeguate misure di sicurezza è fondamentale per ridurre l'esposizione agli attacchi informatici e proteggere l'infrastruttura IT